

Introdução e Conceito

Atualmente, acredito que todos vocês já devam ter percebido o quanto os sistemas de informação, as tecnologias da informação e a própria computação são importantes para as pessoas, sociedades e principalmente organizações, para promover aspectos relacionados a economia, a inovação, o empreendedorismo e porque não dizer a própria evolução social e humana!

No contexto da tecnologia da informação e dos sistemas de informação, os dados e a informação assumem um papel importantíssimo, pois com eles as pessoas, sociedades e principalmente as organizações conseguem alcançar seus objetivos, sonhos, desejos, necessidades e expectativas. Não é por acaso que a frase “Data is the new oil” – traduzida: “os dados são o novo petróleo” criada por Clive Humby, um matemático londrino pesquisador e estudioso da ciência de dados, tornou-se um mantra a ser repetido pelo mundo afora, por muitos consultores, executivos e demais especialistas e entusiastas das tecnologias da informação, segurança da informação e por fim da chamada transformação digital, para expressar o significado e valor de dados e informações.

A frase criada por Humby, vêm ao longo dos últimos anos sendo utilizada para defender a tese de que os dados são tão valiosos quanto o petróleo atualmente e, que se bem trabalhados os dados, posteriormente transformados em informações, são considerados ativos que irão representar fatores de sucesso para qualquer pessoa, sociedade ou organização por meio da utilização dos sistemas de informação. Cabe aqui, apresentarmos alguns conceitos para que você possa compreender melhor o sentido e o significado dado, informação e conhecimento.

De acordo com Turban, Rainer e Potter (2007) dado ou dados (no plural) refere-se a uma descrição elementar de coisas, eventos, atividades e transações que são registrados, classificados e armazenados. Mas não são organizados para transmitir qualquer significado específico. Neste contexto, dados poderão ser qualquer fato bruto, sem sentido ou significado e, que podem ser representados por letras, números, figuras, sons ou imagens, mas, que ainda não foram organizados. Como exemplo podemos citar os valores contidos em uma planilha financeira, medida de

um determinado objeto, horas trabalhadas por um colaborador, as notas de um estudante em uma disciplina e, assim por diante.

Já a informação segundo os mesmos autores, refere-se a dados que foram organizados de modo a terem significado, sentido e valor para quem a recebe e interpreta e o conhecimento consistem em dados e/ou informações que foram organizados e processados em conjunto com outros elementos tais como: entendimento, experiência, aprendizagem acumulada que por sua vez irá gerar valor a quem o tem. Ou seja, o conhecimento nada mais é do que a informação processada e transformada em experiência pelo indivíduo.

Neste contexto, percebe-se que dados e informações são bens ou ativos que possuem um grande valor para as pessoas, sociedades e principalmente organizações, pois deles é obtido o conhecimento e, por serem então a matéria-prima para o conhecimento, dados e informações devem ser protegidos contra quaisquer tipos de ameaças, principalmente aquelas presentes nos meios digitais e nos sistemas e tecnologias da informação.

Tanto se fala e se escuta o termo “Tecnologia da Informação” ou simplesmente “TI”. Mas, afinal você saberia dizer o que é a Tecnologia da Informação? Bem, a Tecnologia da Informação (TI) pode ser compreendida como a relação de recursos de informação de uma organização, seus colaboradores e a gestão que os supervisiona. Na TI está presente toda a infraestrutura de informações e sistemas de informações de um ambiente organizacional e pode ser entendida como o conjunto de recursos e serviços tecnológicos, informáticos ou computacionais que são utilizados para que a organização possa gerar e utilizar a informação.

A TI atualmente é sem dúvida um dos componentes mais importantes e valiosos para qualquer tipo de organização e/ou modelo de negócio, pois dela as organizações podem alcançar seus objetivos estratégicos e operacionais, bem como levar aos seus clientes produtos e serviços que realmente atendam às suas necessidades e expectativas. É importante ressaltar que de acordo com Lastres e Albagli (1999), uma organização encontra-se atualmente em um ambiente dinâmico e o sucesso dela em superar obstáculos e alcançar seus objetivos estratégicos, dependem principalmente dos recursos providos pelas tecnologias da informação, incluindo dados e informações e, da forma como esses serão utilizados, o que a torna uma organização baseada no conhecimento.

Conceito: Segurança da Informação e Segurança Cibernética

Para que você possa atuar como um profissional nas áreas da segurança da informação ou segurança cibernética, é preciso saber sobre alguns conceitos que são considerados alicerces para a proteção das tecnologias da informação.

Ambos os conceitos podem de forma genérica serem compreendidos como a proteção dos ativos de TI, incluindo dados e informações. Porém, a segurança da informação implementa uma proteção mais ampla se comparada com a segurança cibernética, que por sua vez concentra-se na proteção dos mesmos ativos no espaço cibernético, ou seja, na Internet.

De acordo com a norma ISO 27002:2015 a segurança da informação é a proteção da informação contra os mais diversos tipos de ameaças para garantir a continuidade dos negócios, minimizando os riscos e maximizando o retorno sobre os investimentos e as oportunidades de negócio. Ou seja, podemos dizer que a segurança da informação trata-se de um conjunto de mecanismos, técnicas, práticas, procedimentos e normas que irão não só orientar mais também atuar na proteção do conjunto de ativos de TI, compostos por tecnologias, processos e pessoas – incluindo dados e informações contra a perda de um ou mais princípios relacionados à confidencialidade, integridade e disponibilidade, considerados os pilares mais básicos e primordiais a proteção da informação, podendo ainda serem acrescentados outros princípios tais como: autenticidade, não repúdio, confiabilidade, controle de acesso, conformidade, dentre outros.

Já a segurança cibernética pode ser compreendida como uma segmentação específica da segurança da informação contendo seus conjuntos de mecanismos, metodologias, tecnologias, processos, procedimentos e normas que tem como principal objetivo, proteger os mesmos ativos de TI de uma organização contra diversos tipos de ameaças originadas do espaço cibernético, ou seja, da Internet, incluindo os processos de interconexão, armazenamento e transmissão.

É importante ressaltar que ambas – segurança da informação e segurança cibernética fazem parte de um conjunto maior no qual é conhecimento como governança de TI

e, possuem um objetivo comum que é diminuir as ameaças e riscos a um nível aceitável para a organização, que no geral busca-se estar próximo do nível “zero” de incidentes. Afinal, tanto dados, quanto informações são conforme vistos anteriormente ativos valiosos de uma organização, pois deles ela obtém o conhecimento!

Conceito: Vulnerabilidade, Ameaça e Risco

Com relação aos conceitos de vulnerabilidade, ameaça e risco, ambas as seguranças – da informação ou cibernética, consideram:

- Vulnerabilidade – como uma fraqueza – fragilidade, ou ponto fraco presente em um ou mais ativos de TI e, que pode após ser explorada por uma ou mais ameaças comprometer a confidencialidade, integridade ou disponibilidade do ativo explorando, trazendo como consequência algum tipo de falha ou dano ou impacto não desejável, que possa impossibilitar o mesmo de atuar de forma correta, causando assim um incidente de segurança que pode levar a algum tipo de prejuízo a organização, seja: financeiro, operacional, de marca ou reputação, ou qualquer outro tipo.

Como exemplo de algumas vulnerabilidades em TI, podemos citar: bugs em sistemas operacionais, senhas sem complexidade, falta de atualizações em sistemas/aplicativos, falta de programas de treinamento e conscientização sobre segurança da informação ou segurança cibernética, políticas de segurança mal planejadas, criadas ou implementadas, dentre outros... Neste contexto as vulnerabilidades devem ser eliminadas ou mitigadas e, este deve ser foco central das equipes segurança da informação ou segurança cibernética. Afinal, um incidente de segurança sempre irá começar por uma exploração de um ponto fraco por parte de uma ameaça.

- Ameaça – qualquer agente ou ator que explore uma ou mais vulnerabilidades, com o potencial de causar algum evento ou impacto não desejável que traga como consequência algum dano ou perda a organização. É importante ressaltar que com relação a ameaças, elas podem ser de diversos tipos e formas, sendo as mais comuns as ameaças do tipo virtuais, tais como vírus de computadores e

códigos maliciosos e, as ameaças humanas tais como os criminosos cibernéticos, classificados como hackers e crackers.

- Risco – é o resultado decorrente das variáveis: ameaças x vulnerabilidade x probabilidade e impacto. Ou seja, é a concretização de um evento em que o resultado pode ser classificado como um evento positivo ou negativo para a organização. Para a segurança da informação e segurança cibernética um risco é considerado um evento negativo que irá se concretizar causando algum incidente de segurança e consecutivamente algum dano não desejável à organização. Existem diversos tipos de riscos, sendo os mais comuns, os riscos cibernéticos, riscos financeiros, riscos operacionais, riscos técnicos e riscos humanos (involuntários ou não).

Como exemplo podemos citar: falhas na execução de rotinas de backup/restore de dados; falta de planos de continuidade de negócios ou de recuperação de desastres; sistemas desatualizados ou sem correção de bugs, dentre outros...

Equipes/Times de Segurança – Papel e Responsabilidades

Com relação às equipes ou times de segurança, dentro de um ambiente organizacional, poderá haver uma ou mais equipes ou times que irão atuar de acordo com o seu papel e responsabilidade com relação à proteção dos ativos de TI.

No geral, os times são classificados em dois grandes grupos, sendo o primeiro grupo conhecido como “Red Teams” ou “Time Vermelho” que tem como papel atuar de forma mais ofensiva na segurança, realizando praticamente as mesmas atividades que um criminoso cibernético faria. Ou seja, realizam simulações reais ou não de ataques aos mecanismos de defesa de uma infraestrutura de TI, para realizar testes de intrusão, descobrir vulnerabilidades presentes nos ativos de TI e descobrir quais seriam os possíveis impactos e riscos a organização estaria sujeita caso fosse uma situação real. Sendo assim, os “times vermelhos” tem um papel e uma responsabilidade grande no contexto da segurança da informação e segurança cibernética, pois são responsáveis em testar e validar as medidas de proteção implementadas em toda a infraestrutura de TI da organização, atuando assim em conjunto e de maneira parceira com os “blue teams” ou “time azul”.

Do outro lado da moeda temos os “Blue Teams” ou “Time Azul”, que ao contrário do time vermelho, tem o papel de garantir a proteção de toda a infraestrutura de TI – incluindo os ativos, contra os diversos tipos de ameaças. É o time azul, responsável por planejar, implementar, monitorar e gerenciar todas as medidas de proteção para garantir a segurança da informação e segurança cibernética. No geral, atuam em conjunto com o time vermelho e, ficam concentrados no SOC (Security Operations Center – Centro de Operações de Segurança) ou em alguns casos no NOC (Network Operations Center – Centro de Operações de Redes).

Ambos os times – vermelho ou azul – são formados por profissionais com grande habilidade e competência em segurança da informação e segurança cibernética e, são fundamentais para garantir a proteção de toda a infraestrutura de TI em um ambiente organizacional, podendo ainda fazer parte de equipes multidisciplinares, compostas por outras áreas da TI tais como a área de desenvolvimento e áreas operacionais, permitindo a criação de metodologias do tipo SECDEVOPS onde se busca promover a segurança no desenvolvimento de sistemas/aplicações e nas operações do modelo de negócio.

Frameworks, Normas e Melhores Práticas

Para podermos alcançar o sucesso na proteção dos ativos de TI e dentro de um ambiente organizacional – coisa que nem sempre é fácil, precisamos pensar em adotar uma metodologia ou framework que permita com que façamos a coisa certa!

A nossa sorte é que existem diversas metodologias e frameworks consagrados que estão disponíveis para que possamos usar como um “guia” para a implementação de uma proteção da TI de forma eficiente e eficaz.

Para a segurança da informação, temos como exemplo as normas ISO/IEC da família 27000 que auxiliam na construção de uma proteção sólida e eficiente da TI. Em especial as normas ISO/IEC 27001 e 27002 que são destinadas a auxiliar as equipes de TI a implementar um sistema de gestão da segurança da informação eficiente no qual são tratados todos os aspectos, processos e procedimentos relacionados à segurança e proteção não só da informação, mas também de toda a infraestrutura de TI. Já com relação à segurança cibernética, além das normas ISO, citadas, podemos ainda utilizar

alguns frameworks específicos à proteção de ativos no espaço cibernético como, por exemplo, os frameworks propostos pelo NIST – National Institute of Standards and technology – que é formado por diversos especialistas em segurança cibernética e, que tem como propósito sugerir guias contendo as melhores práticas com relação à segurança cibernética. Dentre os guias mais conceituados estão o NIST Framework, que proporciona às equipes de segurança implementares mecanismos, tecnologias, processos e procedimentos que visam: identificar, proteger, detectar, responder e recuperar os ativos e infraestruturas de TI que estejam presentes no espaço cibernético ou em qualquer ambiente virtual.

Conteúdo Bônus

Que tal aprendermos um pouco mais sobre segurança da informação, segurança cibernética e proteção e privacidade de dados na era do conhecimento onde estamos a todo momento acessando e compartilhando dados e informações? Então separei alguns vídeos no Youtube no qual tratam um pouco sobre essas questões.

- Privacidade na era da Internet | Quebrando o Tabu

Documentário do canal GNT.

- Hackers Criminosos e Anjos

Documentário Discovery Channel.

Referência Bibliográfica

ACKOFF, R. L. **From Data to Wisdom**. Journal of Applied Systems Analysis, v.16, p 3-9. [s.l.] 1989.

CUNHA, Murilo Basto da. **Dicionário de Biblioteconomia e Arquivologia**. Brasília: Briquet de Lemos Livros, 2008. 451p.

ABNT NBR ISO/IEC 27002:2013. **Tecnologia da informação – Técnicas de Segurança – Códigos de prática para controles de segurança da informação**.

Disponível: < <https://www.abntcatalogo.com.br/norma.aspx?Q=Q0l4Qy9lSjZqVnpBaEhIb2MzMHUzYmJ3N1h0cnBVVTZLN1g5R2lXSVEbz0=>>.

LASTRE, H. M. M., ALBAGLI, S. (Org.). **Informação e globalização na era do conhecimento**. Rio de Janeiro: Campus, 1999. 318p.

TURBAN, Efraim. RAINER, R. Kelly. POTTER, Richard E. **Introdução a Sistemas de Informação**. – Rio de Janeiro: Elsevier, 2007. – 2ª reimpressão.